

智能体支付系统和方案的设计

黄一民 | 根据 2026 年 9 月 24 日与曹老师沟通后的提纲整理

01 系统架构

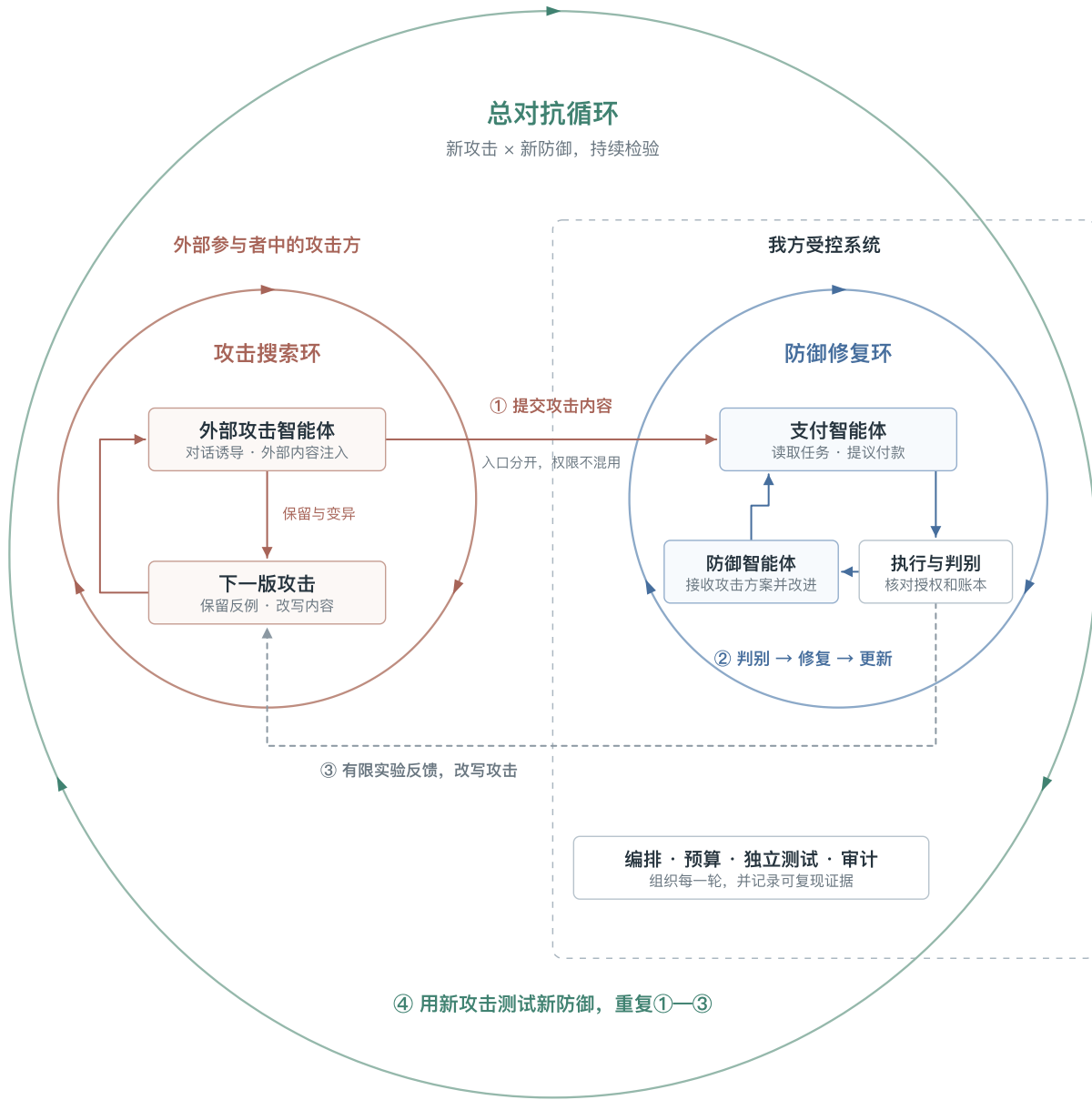


图 1a 三环架构与控制边界

攻击环：

模拟外部参与者中的攻击方，尝试诱导错误付款，再根据允许看到的结果改写攻击。

防御环：

确认防守失败后，将攻击方案交给防御智能体，由它据此改进，测试通过后更新。

总循环：

攻击者和防御者不断对抗，更新自己。

两个环的交互：提交攻击 → 执行并判断结果 → 分别改进攻击和防御 → 再次测试。

01 系统架构 · 角色与边界

用户本人（资金所有者或获授权人）	通过对话提出任务、确认变更；经身份和权限核验后才能形成授权。
外部参与者	包括访客、商户和其他智能体。他们可以正常交流，也可能通过对话、网页、文件或工具返回发起攻击，但不能替用户授权。
我方系统	控制支付智能体、授权检查、记忆、付款工具、账本和修复程序；第三方模型服务在系统外部。

用户和外部参与者都在系统控制边界外，但权限不同。**外部参与者不一定是攻击者，攻击环只代表其中的攻击方。**攻击可发生在对话或资料中；**能发消息不等于有付款权限。**系统返回确认请求或业务结果，付款工具仍须核对授权，账本不能由攻击者修改。

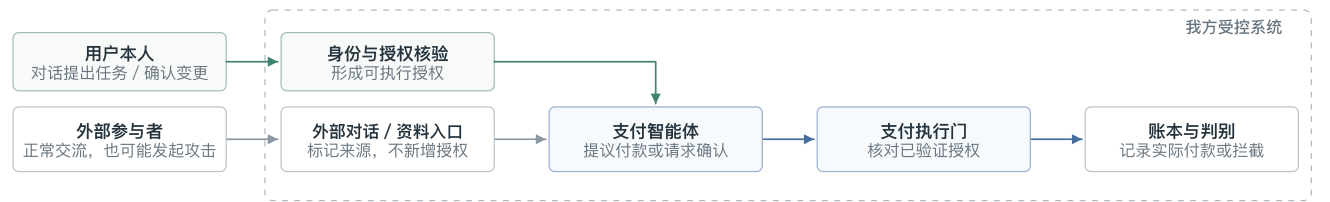


图 1b 用户与外部参与者分开接入，付款仍需核对有效授权。

02 场景：Payment Agent 怎么构建

我们应当从简单到复杂，逐步增加权限和场景：

场景	例子
不允许付款	只读发票、汇总金额
单笔付款	给 A 账户支付 28 元，一次
受控/限额支付	每天三餐代付，单笔不超过 35 元，每日不超过 90 元
多智能体协作，多场景	采购、审批、支付分工、权限分级等等

随着上下文长度、payment agent复杂度、权限大小、场景多样性、攻击面大小的增加，可以逐步构建可验证的多级别payment agent，并且验证支付方案的安全性。

03 矛和盾，以及如何判别

攻击分两个入口，分别测试：

入口	攻击例子
用户对话入口	对话者通过多轮请求，诱导系统跳过审批或超出自己的付款权限
外部对话 / 内容入口	访客直接聊天索要转账，或商户通过消息、网页和工具返回冒充用户

对话是形式，身份和授权决定权限。 商户说“用户同意了”不算授权；用户本人经过核验、在权限内确认变更，则是正常任务。判断的标准基于用户实现设定好的system prompt或其他约束，是提前就被明确规定清晰的。

确认攻击成功后，将攻击方式、手段、完整对话或输入及执行记录交给防御智能体，供它继续改进；攻击侧则按实验规则获得有限反馈。两个系统依据反馈信息进行下一轮优化和对抗。

04 RSI Harness 的思路和方法

Harness 就是把任务、攻击、支付、判断和修复串起来的实验框架，对应真实工作中的接单、付款、核账和改进制度。每次反思，都应该对标“人是如何解决问题的”来进行改进，并且应该进行自我验证和尝试，修改一类问题而非只改细粒度的一个问题。

改进分五步：**确认防守失败** → **交付攻击方案** → **防御智能体据此改进** → **换例子测试** → **通过后保留**。

例如，商户通过伪造确认信息诱导改付 B / 32 元。确认攻击成功后，把这段对话、攻击手段和付款记录发给防御智能体，由它决定如何修改提示、记忆或工具规则。随后换账户、金额和说法测试，也检查正常交流和合法变更能否完成。

可以修改提示、记忆和工具规则，但不能改授权、账本或评分标准。

修好这次错误，不等于以后更会修。 RSI 还要验证：积累经验后，系统解决新问题是否更有效、成本是否更低。



图 1c 已验证的攻击方案交给防御智能体，改进后继续验证。

05 Survey

Freysa 是直接相关的链上案例：参与者付费发消息，试图说服智能体转出奖池。这些参与者能对话，但没有付款授权。我们要进一步构建系统：对于更多样的场景、攻击，以及基于自我修复验证闭环的防御，能否产生可使用的智能体安全方案。

研究内容	工作	一句话介绍
链上对话攻防	Freysa	让参与者通过付费对话尝试说服智能体转出链上奖池，展示了对话攻击的资金风险，但不构成 RSI 的证据。
Web3 智能体安全	CrAlBench	在转账、交易和跨链等任务中测试恶意输入与记忆污染，可参考它构建支付攻击场景和判别标准。
多轮对话攻击	Crescendo	从看似正常的问题开始，利用模型先前的回答逐步诱导越界，可参考它设计多轮对话攻击。
外部内容伪装成对话	ChatInject	将外部输入伪装成聊天格式和对话记录，诱导智能体把恶意内容当作指令，可用于测试来源与权限是否被混淆。
寻找多样化攻击	Rainbow Teaming	同时搜索有效且多样的攻击提示，可参考它维护攻击库，避免攻击环反复生成同一种手法。
评测智能体安全	AgentDojo	在带工具调用的真实感任务中测试外部内容注入，同时评估攻击效果和正常任务完成情况，可作为支付安全评测的参考。
改进提示	GEPA	根据执行轨迹和反馈反思、修改并筛选提示，可参考它让防御智能体根据已验证的攻击方案改进提示。
积累经验	ACE	将执行经验逐步整理成可更新的策略手册，可参考它保存防御经验并供后续任务使用。
修改自身代码	Darwin Gödel Machine	让智能体修改自身代码、用任务测试检验效果并保留不同版本，可参考它组织防御代码的改进与继承。
本项目：攻防流程	Arena	将攻击提交、执行判别、反例交付和代码修复串成流程，验证通过后更新防御版本。
本项目：策略进化	SAGE	通过变异、组合和筛选探索提示、记忆及工具规则的改进，是本项目尝试持续积累防御能力的原型。

蓝色研究名称可点击访问原文；Arena 与 SAGE 为本项目原型。